VAPT TASK

1. Executive Summary

This report documents the Vulnerability Assessment and Penetration Testing (VAPT) performed in a controlled virtual lab environment using Kali Linux as the attacker machine and Metasploitable2 as the target system. The objective of this task was to understand basic security assessment concepts, identify vulnerabilities using open-source tools, and document all findings.

The assessment included network configuration, connectivity testing, vulnerability scanning, manual analysis, CVSS scoring, and preparation of a risk matrix.

2. Scope of Assessment

2.1 In-Scope

- Kali Linux Virtual Machine
- Metasploitable2 Virtual Machine
- Internal Host-Only network
- Service enumeration and vulnerability identification
- Documentation and risk assessment

2.2 Out-of-Scope

- Real-world systems
- Internet-facing assets
- Full exploitation or post-exploitation
- Automated OpenVAS scan output

3. Methodology

3.1 Planning

The objective and scope of the task were defined. The environment consisted of VirtualBox hosting Kali Linux and Metasploitable2. Network communication was set up using Host-Only Adapter mode.

3.2 Discovery

Nmap was used to perform host discovery and service enumeration. Version scanning and aggressive scanning provided detailed information about the target system's open ports and running services.

3.3 Vulnerability Identification

Identified services were manually analyzed using publicly available vulnerability references, outdated service signatures, misconfigurations, and known CVEs.

3.4 Reporting

All findings were documented in a structured spreadsheet and summarized using a risk matrix. Screenshots were collected as evidence for each step.

3.5 OpenVAS Note

OpenVAS was initiated; however, the feed sync could not be completed due to network adapter constraints inside the virtual machine. As a result, Nmap was used for enumeration and vulnerability identification.

---

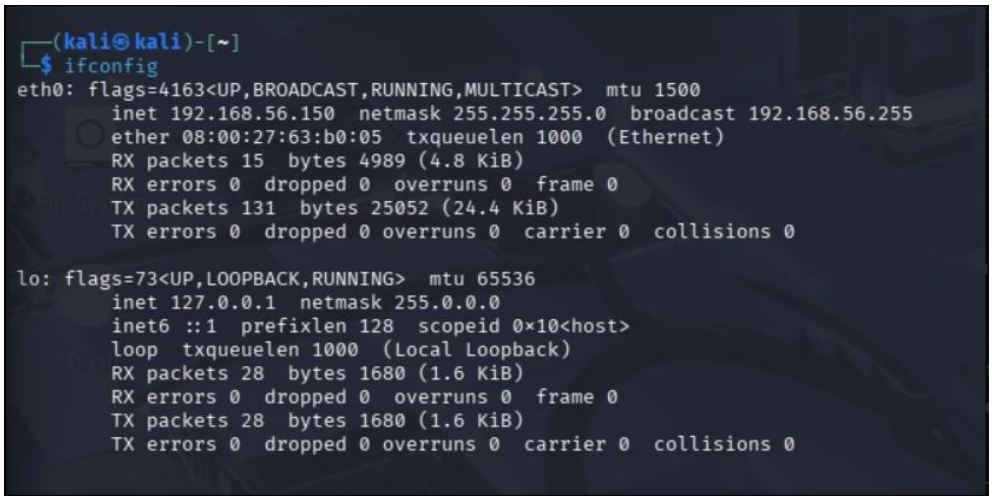
4. Environment Setup

4.1 Virtual Machine Configuration

- Kali Linux (Attacker Machine)
- Metasploitable2 (Target Machine)

4.2 Network Configuration

Both machines were connected using a Host-Only Adapter to enable isolated communication.



```
┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.56.150  netmask 255.255.255.0  broadcast 192.168.56.255
        ether 08:00:27:63:b0:05  txqueuelen 1000  (Ethernet)
        RX packets 15  bytes 4989 (4.8 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 131  bytes 25052 (24.4 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 28  bytes 1680 (1.6 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 28  bytes 1680 (1.6 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

Figure 1: Kali Linux network interface configuration

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:c1:84:27
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fec1:8427/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3887 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3503 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:379402 (370.5 KB)  TX bytes:625151 (610.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:600 errors:0 dropped:0 overruns:0 frame:0
          TX packets:600 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:236457 (230.9 KB)  TX bytes:236457 (230.9 KB)
```

Figure 2: Metasploitable2 network interface configuration

5. Network Connectivity Verification

Connectivity between Kali and Metasploitable2 was validated using the ping command.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=2.04 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.775 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.900 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.960 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.514 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.965 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.989 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.921 ms
64 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=1.08 ms
64 bytes from 192.168.56.101: icmp_seq=10 ttl=64 time=1.10 ms
64 bytes from 192.168.56.101: icmp_seq=11 ttl=64 time=0.985 ms
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=1.06 ms
^C
── 192.168.56.101 ping statistics ──
12 packets transmitted, 12 received, 0% packet loss, time 11039ms
rtt min/avg/max/mdev = 0.514/1.023/2.039/0.341 ms
```

Figure 3: Successful connectivity test from Kali to Metasploitable2

6. Vulnerability Scanning Using Nmap

6.1 Version Scan (-sV)

A version scan was performed to identify services and associated versions running on the target machine.

```
┌──(kali㉿kali)-[~]
└─$ nmap -Pn -sV 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 01:05 -0500
Nmap scan report for 192.168.56.101
Host is up (0.00014s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C1:84:27 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.35 seconds
```

Figure 4: Nmap Version Scan showing active ports and service versions

6.2 Aggressive Scan (-A)

An aggressive scan was executed to gather detailed information including OS detection, script output, and service configurations.

An aggressive scan was used because it gives more detailed information than the normal scan. This scan helped in identifying the operating system, service versions, and extra details that Nmap scripts could detect on their own.

It also showed more information about each service like what features were enabled, whether any default or weak configurations were present, and how the target machine responded to different checks. Overall, this scan gave a clearer picture of the system and helped in understanding the vulnerabilities more easily.

```
┌──(kali㉿kali)-[~]
└─$ nmap -A -Pn 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 01:06 -0500
Nmap scan report for 192.168.56.101
Host is up (0.00091s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.150
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
 ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O
COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-02-25T05:53:38+00:00; -12m54s from scanner time.
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

Figure 5: Nmap Aggressive Scan revealing deeper service enumeration

8. Identified Vulnerabilities

Based on Nmap results and manual analysis, the following vulnerabilities were identified:

- vsftpd 2.3.4 backdoor vulnerability

- Outdated OpenSSH version
- Telnet service transmitting credentials in cleartext
- SMTP VRFY/EXPN user enumeration
- Outdated Apache web server
- RPC service exposure
- Samba 3.0.20 remote code execution risk
- MySQL/PostgreSQL weak authentication
- Apache Tomcat default credentials
- Backdoor shell on port 1524

9. Vulnerability Summary Table

A structured spreadsheet was prepared to document service details, vulnerabilities, risks, and CVSS scores.

Port	Service	Version	Vulnerability	Description	Risk	CVSS
21	FTP	vsftpd 2.3.4	Backdoor Command Executic	Contains a malicious backdo	Critical	9.8
22	SSH	OpenSSH 4.7p1	Outdated SSH Version	Multiple known vulnerabilities	Medium	5.3
23	Telnet	Linux telnetd	Cleartext Communication	Credentials transmitted unen	High	7.5
25	SMTP	Postfix smtpd	User Enumeration	VRFY/EXPN commands allov	Medium	5
80	HTTP	Apache 2.2.8	Outdated Web Server	Vulnerable to multiple CVEs:	High	7.5
111	RPCbind	2-4	RPC Exposure	Exposes NFS/mountd; attack	High	7.8
139/445	SMB	Samba 3.0.20	Remote Code Execution	Vulnerable to "username map	Critical	10
3306	MySQL	5.0.51a	Weak Authentication	Default or weak passwords lil	Medium	6.5
5432	PostgreSQL	8.3.0	Weak Configuration	Default credentials; remote d	Medium	6
8180	Apache Tomcat	1.1	Default Credentials	Common default login: tomca	High	7.5
1524	Insecure Shell	Metasploitable Backdoor	Root Shell Access	Direct root shell available witl	Critical	10

Figure 6: Vulnerability Tracking Sheet containing detailed analysis

10. Risk Matrix Summary

Risk Level	Count
Critical	3
High	4
Medium	4
Low	0

Figure 7: Risk categorization of identified vulnerabilities

11. Remediation Recommendations

- Update vsftpd to remove backdoor vulnerability
- Disable Telnet and replace with SSH
- Update Apache, Samba, SSH, and Tomcat to latest versions
- Remove default credentials from all services
- Enforce strong database passwords
- Restrict or disable RPC and unnecessary services
- Remove unauthorized backdoor shells
- Apply OS-level hardening (CIS Benchmarks)
- Configure firewall to block unnecessary ports

12. Conclusion

This VAPT task demonstrated the fundamental steps involved in assessing a vulnerable system using open-source tools.

Through network setup, scanning, vulnerability identification, and documentation, all primary objectives were successfully met.

Multiple high-risk vulnerabilities were discovered, confirming the intentionally insecure nature of Metasploitable2.

A complete vulnerability spreadsheet and risk matrix were prepared according to the required documentation format.

13. References

- NIST Security Assessment Guidelines
- OWASP Testing Guide
- CIS Benchmarks
- Nmap Documentation
- CVSS Calculator – NVD
- Metasploitable2 Project Documentation